

NIS2 Compliance Assessment Report

Organization: Metropolitan Teaching Hospital (Large)

Date: 2026-06-12

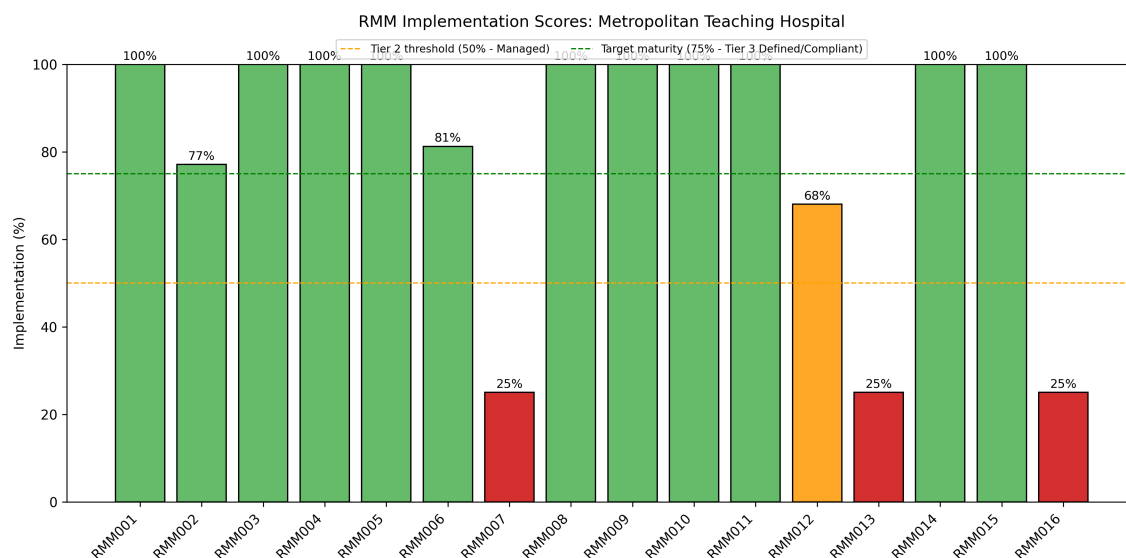
Data source: Large academic medical centre (constructed from public NCSC/HSE/ENISA benchmarks)

Overall Score	83.5%
Maturity Tier	Tier 3 - Defined (Compliant)
Target Maturity	75% (Tier 3 - Defined/Compliant)

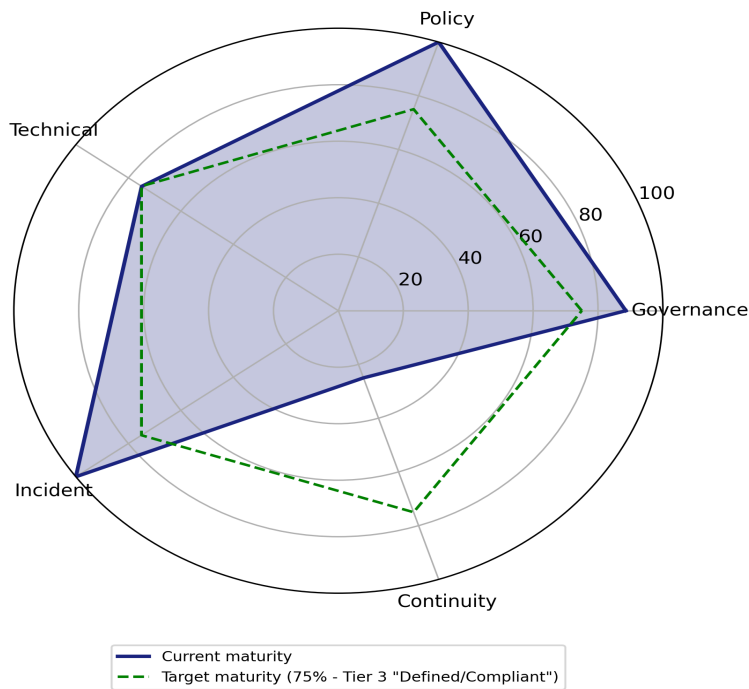
How to read this score. Each question is answered Yes (4 pts), Partial (1 pt) or No (0 pts) and multiplied by a weight (critical controls such as MFA and 24h reporting carry higher weight, so RMM scores are *not* weighted equally). Each answer is further scaled by an evidence-assurance factor (None 0.0 / Low 0.5 / Medium 0.8 / High 1.0), so claims without evidence score lower. The overall percentage is the weighted, assurance-adjusted total divided by the maximum achievable. Maturity tiers: Tier 1 Initial 0-49%, Tier 2 Managed 50-74%, Tier 3 Defined/Compliant 75-89%, Tier 4 Optimized 90-100%. The target for a large healthcare entity is Tier 3 (75%). For this assessment the assurance-adjusted weighted score is 123.6 of a possible 148.0 points = 83.5%, placing the organization in Tier 3.

Executive Risk Statement

As of 2026-06-12, Metropolitan Teaching Hospital scores 83.5% (Tier 3 - Defined (Compliant)) against NIS2 risk-management requirements. The organization substantially meets NIS2 expectations, with residual gaps to close and sustain. The weakest areas are Asset Mgmt, Secure Dev, Continuity. Unremediated gaps directly threaten patient safety (loss of access to EHR, imaging and medication systems), the continuity of clinical services (ransomware or outage with no tested recovery), and expose the organization to legal and regulatory liability under NIS2. This includes management accountability and potential penalties. Leadership should treat the items below as a time-bound program: address the 30-day actions immediately, fund the 60- and 90-day actions in this budget cycle, and review progress against the target maturity at the next board meeting.



Maturity Profile: Metropolitan Teaching Hospital



The solid blue area is the current maturity by domain; the green dashed line is the target profile (75%, Tier 3 'Defined/Compliant'). A regional hospital delivers essential healthcare services and is treated as an 'essential entity' under NIS2 (Annex I), so it is expected to reach the Defined/Compliant tier with controls fully documented, implemented and routinely tested, rather than merely Managed. Tier 4 (Optimized) is not required for compliance. Gaps between the blue area and the green line are the work still required in each domain.

Priority Remediation Plan

Each gap below the target maturity has a control-specific action with an accountable owner, due window, dependencies and the evidence required to close it.

RMM	Now	Target	Priority	Control-specific remediation
RMM007 Asset Mgmt	25%	90%	Critical	Maintain an automated, up-to-date asset inventory with ownership and criticality tags. Owner: IT Operations Lead Due: 60 days Depends on: CMDB / network discovery tooling Evidence: Asset inventory export with last-updated timestamps
RMM013 Secure Dev	25%	85%	Critical	Build security requirements into system acquisition and run vulnerability management across new systems. Owner: IT Architecture / CISO Due: 90 days Depends on: Procurement process (RMM012) Evidence: Secure acquisition checklist and vulnerability scan reports
RMM016 Continuity	25%	90%	Critical	Define a BCP with documented RTO/RPO for each critical system like EHR, PACS, LIS, medication systems, and network services. Test disaster recovery annually. Owner: IT Operations / Business Continuity Manager Due: 90 days Depends on: Critical-asset register (RMM004), DR environment Evidence: BCP with per-system RTO/RPO table and annual DR test report

RMM	Now	Target	Priority	Control-specific remediation
RMM012 Supply Chain	68%	85%	Medium	Risk-assess critical vendors and embed security SLAs and right-to-audit clauses in supplier contracts. Owner: Procurement / CISO Due: 90 days Depends on: Vendor list and legal review Evidence: Vendor risk assessments and updated contracts

30-60-90 Day Remediation Roadmap

Sequenced view of the same actions so management can track progress towards target maturity after this assessment.

Window	RMM	Now	Target
Days 31-60 (Short term)	RMM007 Asset Mgmt	25%	90%
Days 61-90 (Medium term)	RMM013 Secure Dev	25%	85%
	RMM016 Continuity	25%	90%
	RMM012 Supply Chain	68%	85%

Business Continuity: Critical System Recovery Objectives

Recovery Time Objective (RTO) and Recovery Point Objective (RPO) targets for the hospital's critical systems (basis for RMM016). These objectives are validated by the disaster-recovery test schedule below.

Critical system	Criticality	RTO	RPO	Key dependency
Electronic Health Record (EHR)	Tier 1 - Critical	4 hours	15 minutes	Core network, identity
Medication management (ePMA / eMAR)	Tier 1 - Critical	2 hours	15 minutes	EHR, core network
Laboratory Information System (LIS)	Tier 1 - Critical	4 hours	30 minutes	EHR, core network
Picture Archiving & Communication (PACS)	Tier 2 - High	8 hours	1 hour	Storage, core network
Core network & identity (AD / DNS / DHCP)	Tier 1 - Critical	1 hour	15 minutes	Power, data center

Disaster-recovery test schedule

Frequency	Test	Owner
Quarterly	Backup restore test of one Tier 1 system (rotating schedule)	Infrastructure Lead
Semi-annually	Incident & DR tabletop exercise (clinical + IT participants)	CISO / SOC Lead
Annually	Full DR failover test with main-network isolation	IT Operations / BC Manager

Incident Reporting & 24-Hour Early-Warning Readiness (Art. 23)

Operational proof that the organization can submit a NIS2 'early warning' within 24 hours of becoming aware of a significant incident.

Element	Detail
Reporting owner	SOC Lead (primary); Duty IT Manager (deputy)
Escalation route	SOC analyst -> SOC Lead -> CISO -> Executive on-call -> national CSIRT / NCSC
Out-of-hours cover	24/7 on-call rota (ref OPS-ROTA-2026), 15-minute acknowledgement SLA
Reporting template	NCSC early-warning template TMPL-EW-01 (held in IRP-PROC-007 v1.0)

Element	Detail
Statutory timeline	Early warning within 24h, incident notification within 72h, final report within 1 month
Test evidence	Simulated early-warning submission TEST-EW-2026-01, completed 2026-03-08

Appendix: Detailed Findings

ID	RMM	Article	Question	Resp.	Assur.	Evidence (document reference)	Pts
1	RMM001	Art.20(1)	Is there a designated officer for NIS2 compliance?	Yes	High	NIS2 Compliance Officer appointed and board-ratified (Group CISO, ref GOV-NIS2-2025-01); pre-registration pack prepared for NCSC portal.	4.0
2	RMM002	Art.20(1)	Does the board explicitly approve cyber measures?	Yes	High	Board Risk & Cyber Committee charter BRC-CHTR-2025; cyber a standing board agenda item; measures approved in BM-2026-Q1.	6.0
3	RMM002	Art.20(1)	Is there an approved cyber budget for 18 months?	Partial	Medium	Cyber programme funded on a rolling annual capital cycle (FIN-CAP-2026); 18-month forward commitment not yet formally minuted.	1.0
4	RMM002	Art.20(2)	Do board members undergo mandatory cyber training?	Yes	High	Mandatory board cyber-governance training completed 2026-01 (LMS-BOARD-2026-01, 100% completion).	4.0
5	RMM003	Art.21(2)(a)	Is there a documented Security Policy (ISMS)?	Yes	High	ISO/IEC 27001-aligned ISMS policy suite ISMS-POL v4.1, certified scope covers core clinical systems; owner Group CISO.	6.0
6	RMM003	Art.21(2)	Does policy cover all NIS2 risk areas?	Yes	High	Policy coverage matrix POL-MAP-2026 maps every Art.21(2) area and all 16 NCSC RMMs to an owned policy.	4.0
7	RMM004	Art.21(2)(a)	Are risk assessments conducted annually?	Yes	High	Annual enterprise risk assessment RA-2026-ACAD (ISO 27005), refreshed quarterly for high-risk research systems.	6.0
8	RMM004	Art.21(2)(a)	Are critical assets (e.g., EHR) formally identified?	Yes	High	Critical Asset Register CAR-2026 v3.0; EHR, PACS, LIS, ePMA, research HPC classified; owner IT Asset Manager.	4.0
9	RMM005	Art.21(2)(f)	Are measures audited/tested annually?	Yes	High	Independent internal audit IA-CYBER-2026-02 and annual third-party penetration test PEN-2026-01 on record.	4.0
10	RMM005	Art.21(2)(a)	Is there a process to update measures post-incident?	Yes	High	Post-incident review standard PROC-IR-004 v2.0; lessons-learned feed control updates (PIR register 2025-2026).	4.0
11	RMM006	Art.21(2)(e)	Is patching performed within defined SLAs?	Yes	High	Risk-based patch SLA policy ITS-STD-007 v2.1 (critical 72h, high 14d); Tenable + WSUS/Intune compliance >95%.	6.0
12	RMM006	Art.21(2)(c)	Are backups tested for restorability annually?	Yes	High	Quarterly backup restore tests BKP-RESTORE-2026-Q1/Q2; immutable backups; owner Infrastructure Lead.	6.0
13	RMM006	Art.21(2)(g)	Is cyber hygiene training mandatory for all staff?	Partial	High	Security awareness mandatory; completion 88% (LMS-RPT-2026-05); rolling enforcement for remaining clinical staff.	1.0
14	RMM007	Art.21(2)(i)	Is the asset inventory up-to-date?	Partial	High	CMDB (ServiceNow) strong for IT; networked medical devices/OT only ~70% inventoried (MDS-GAP-2026-01).	1.0

ID	RMM	Article	Question	Resp.	Assur.	Evidence (document reference)	Pts
15	RMM008	Art.21(2)(i)	Are background checks performed for sensitive roles?	Yes	High	Garda vetting and pre-employment screening register HR-VET-2026 for clinical/privileged roles.	4.0
16	RMM008	Art.21(2)(i)	Are access rights revoked immediately upon exit?	Yes	High	Automated joiner-mover-leaver via IGA (SailPoint); leaver deprovisioning SLA <2h; sample SNOW-LVR-2026.	4.0
17	RMM009	Art.21(2)(j)	Is MFA enforced for ALL remote/admin access?	Yes	High	Enterprise MFA (Entra ID + FIDO2) enforced for all remote and privileged access; coverage report IAM-RPT-2026-06 = 100%.	8.0
18	RMM009	Art.21(2)(j)	Is 'Least Privilege' strictly enforced?	Yes	High	PAM (CyberArk) for privileged accounts; least-privilege RBAC recertified quarterly PAR-2026-Q1.	4.0
19	RMM010	Art.21(2)	Are physical server rooms secured?	Yes	High	Tier III data centres, badge + biometric access, environmental monitoring; audit FAC-ENV-2026.	4.0
20	RMM011	Art.21(2)(h)	Is patient data encrypted at rest?	Yes	High	Encryption at rest (TDE + full-disk) across clinical databases and endpoints; KMS-managed keys CRY-STD-005 v2.	6.0
21	RMM011	Art.21(2)(h)	Is data encrypted in transit (TLS)?	Yes	High	TLS 1.2/1.3 enforced (grade A, SSLSCAN-2026-05); mTLS for sensitive integrations.	4.0
22	RMM012	Art.21(2)(d)	Do supplier contracts include security SLAs?	Yes	High	Security schedules + right-to-audit in top-50 supplier contracts; standard NIS2 clause library LEG-CYB-2026.	6.0
23	RMM012	Art.21(2)(d)	Are critical vendors risk-assessed?	Partial	Medium	Top clinical vendors risk-assessed (TPRM-2026); academic research collaborators and grant-funded SaaS only partially covered.	1.0
24	RMM013	Art.21(2)(e)	Is security built into system acquisition?	Partial	High	Secure-by-design gate SDLC-CHK-009 applied to enterprise procurements; bespoke research/clinical-trial systems inconsistently gated.	1.0
25	RMM014	Art.21(2)(b)	Is there a documented Incident Response Plan?	Yes	High	Board-approved Incident Response Plan IRP-PLAN-006 v2.0; 24/7 SOC; playbooks for ransomware/EHR outage.	6.0
26	RMM014	Art.21(2)(b)	Has the IRP been tested (tabletop) in 12 months?	Yes	High	Two exercises in 12 months: ransomware tabletop TTX-2025-11 and live red-team RT-2026-02.	4.0
27	RMM015	Art.23(3)	Can you submit an 'Early Warning' within 24h?	Yes	High	24h early-warning runbook IRP-PROC-007 v2.0; named owner, on-call rota; validated test submission TEST-EW-2026-02.	8.0
28	RMM015	Art.21(2)(b)	Are detection mechanisms (IDS/SIEM) in place?	Yes	High	24/7 SOC with Microsoft Sentinel SIEM + MDR; EDR on all endpoints; detection coverage report SOC-2026-Q2.	4.0
29	RMM016	Art.21(2)(c)	Is there a Business Continuity Plan with RTOs?	Partial	High	BCP BCP-PLAN-010 v2.0 with RTO/RPO for Tier 1 systems validated at main campus; satellite-site continuity not fully validated.	1.5
30	RMM016	Art.21(2)(c)	Are DR procedures tested annually?	Partial	High	Annual DR failover proven for primary data centre (DR-TEST-2026-03); full multi-site failover incl. medical devices not yet exercised end-to-end.	1.5